

NITROENCLAVE • EXECUTIVE BRIEF

Elastic Enclave HSM

HSM-grade custody for EJBKA PKI + SPIRE zero-trust — autoscaled on spot EC2

FIPS 140-3 Level 1 custody • PQC-native (ML-DSA / ML-KEM / hybrid)

ELASTIC
Pay for load

HSM-GRADE CUSTODY
FIPS 140-3 L1

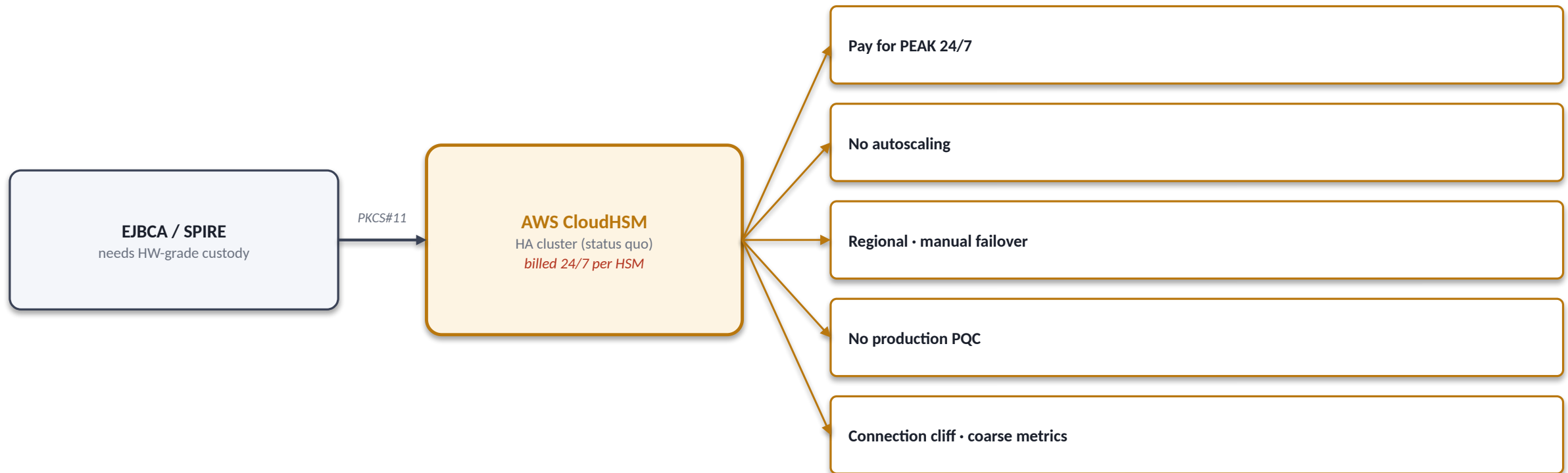
PQC-NATIVE
Quantum-ready

ENTERPRISE RESILIENCE
Self-healing

One attested signer • behind an autoscaling multi-AZ fleet • key never leaves the enclave

The problem — HSM cost & rigidity

EJBCA PKI and SPIRE zero-trust both need hardware-grade key custody — the CA/ICA and SVID-signing keys must live behind a real isolation boundary. But CloudHSM forces you to pay for peak: a fixed, always-on cluster billed 24/7 whether you sign 10 TPS or 10,000.



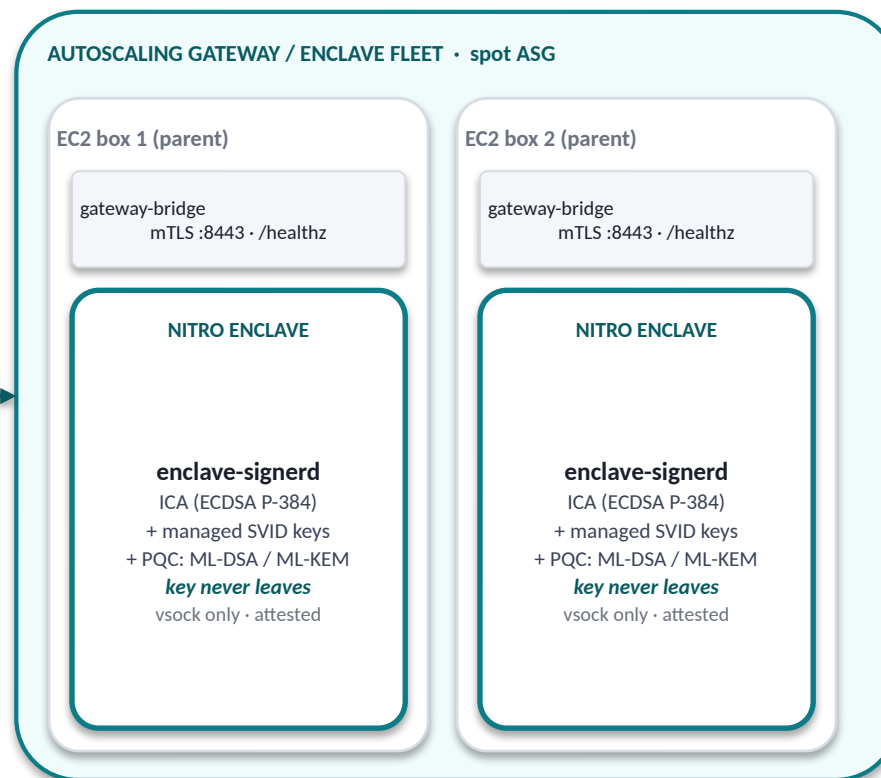
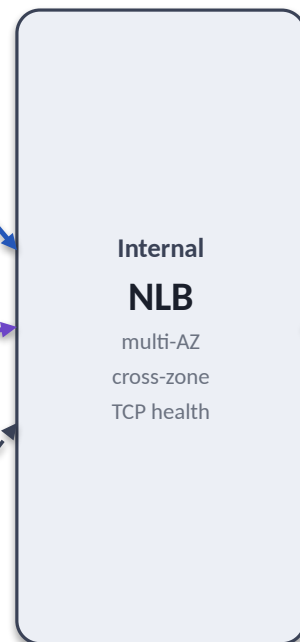
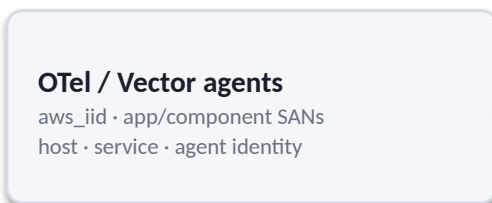
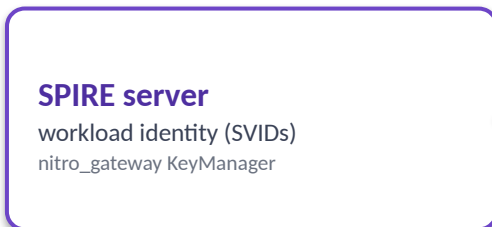
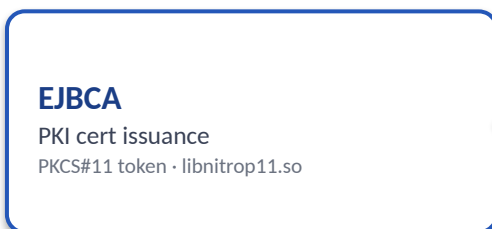
Status quo: expensive and rigid.

CloudHSM: provision for peak, pay for peak — no scale-to-load.

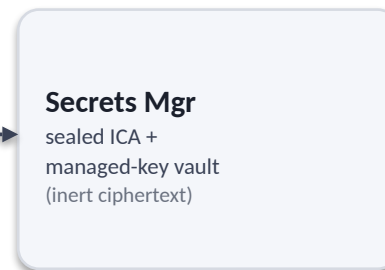
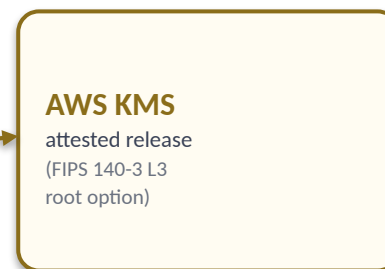
Solution architecture — attested signer behind an autoscaling fleet

One elastic enclave HSM serves EJBCA PKI and SPIRE zero-trust — key never leaves the enclave

IDENTITY CONSUMERS



AWS TRUST ANCHOR



Performance — measured on AWS, honestly labeled

HSM CEILING

~8.6k/box → ~48k fleet

EJBCA ISSUANCE

~895 certs/s/node

SPIRE ISSUANCE

~236 SVIDs/s

Per-cipher enclave ceiling • concurrency 512 • 0 errors

Cipher / mechanism	Signs/sec	Family
ECDSA P-384	7,530	classical
ML-DSA-65 (PQC)	6,261	post-quantum
ML-KEM-1024	8,478	post-quantum
ECDSA P-256	4,374	classical
RSA-2048	2,888	classical

Raw ceiling ≠ product issuance

The signer's raw ceiling is the crypto primitive. Product throughput is service-bound — EJBCA's parse / assemble / DB-write pipeline and the SPIRE server — not the signer.

Headroom: ~10× over EJBCA issuance, ~36× over SPIRE issuance.

The signer is never the bottleneck — ~10–36× headroom. Scale EJBCA / SPIRE nodes, not the signer.

Zero-trust — OpenTelemetry agent auth by app + component

At deploy time each instance is tagged **app=<app>** and **component=<component>**. SPIRE's aws_iid node attester signs those tags into a SPIFFE SAN at three levels — host, service-component, and agent.

Host / node

spiffe://td/node/<app>

the attested EC2 instance (aws_iid, tag:app)

Service / component

spiffe://td/app/<app>/component/<component>/...

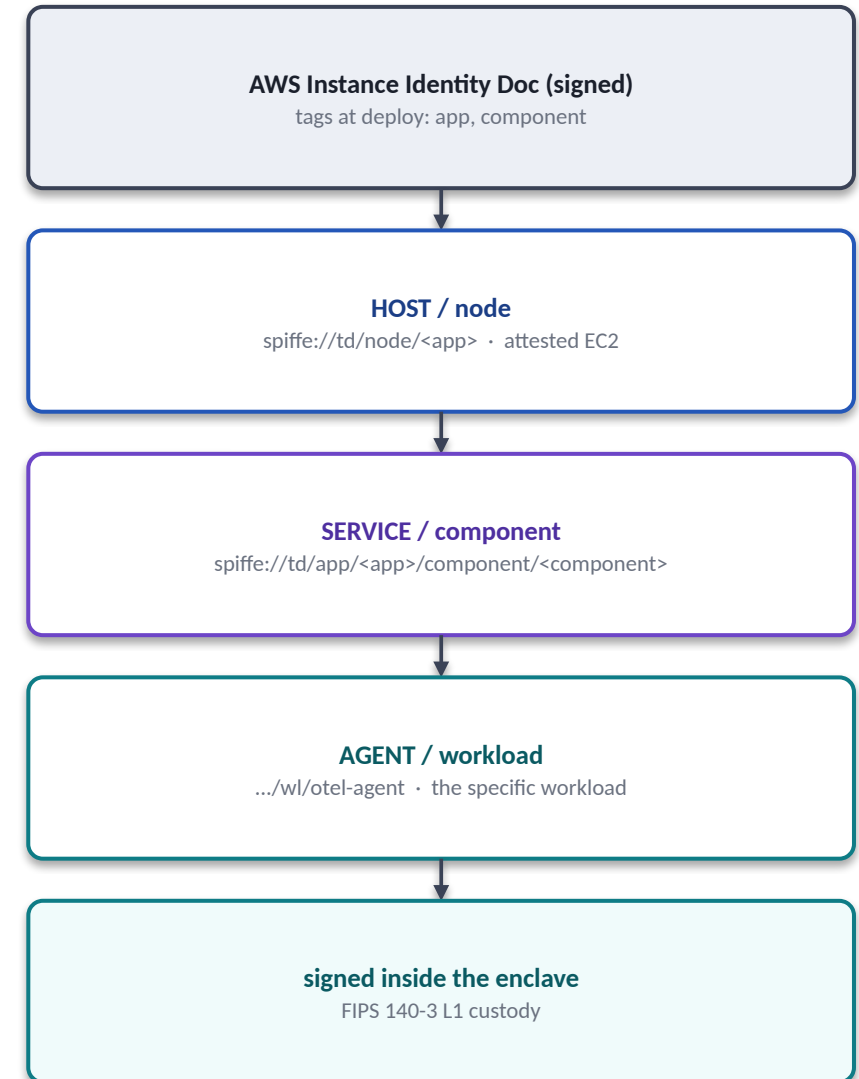
the application component — set from deploy-time tags, not inferred

Agent / workload

.../wl/otel-agent

the specific workload on the node (unix selector)

Every SVID is signed inside the enclave = true zero trust.



Resilience & economics

Self-healing

Enclave-aware /healthz vsock-probes the live enclave — CPU and signing backlog, not just "is the process up."

A wedged enclave → 503 → NLB drains the node → the ASG auto-replaces it.

No AWS API calls in the health path — the probe stays fast and cannot be throttled when you need it most.

Validated self-healing under chaos on real spot infrastructure.

Economics

No dedicated HSM. Spot EC2 + KMS attested release — no 24/7 per-HSM bill, no cluster to stand up.

Scale-to-min when idle. Autoscale down between bursts — you pay for load, not for peak capacity you rarely use.

Linear scale-out. Add boxes → +throughput, behind a multi-AZ, cross-zone internal NLB. Capacity tracks demand.

PQC without new hardware. ML-DSA / ML-KEM / hybrid in software today — no HSM firmware refresh, no CapEx.

SIGNAL
enclave CPU + backlog

HEAL
auto-replace